

State of Maine

Department of Administrative and Financial Services

Office of Information Technology

Access Control Procedures for Users (AC-2, 3, 5, 6, 17, 18, and 19)

Table of Contents

1.0. Document Purpose 3
2.0. Scope 3
3.0. Procedure Conflict 3
4.0. Roles and Responsibilities 3
5.0. Management Commitment 3
6.0. Coordination Among Agency Entities 3
7.0. Compliance 3
8.0. Procedures 4
9.0. Document Details 21
10.0. Review 21
11.0. Records Management 21
12.0. Public Records Exceptions 22
13.0. Definitions 23
14.0. Abbreviations 26

Access Control Procedures for Users (AC-2, 3, 5, 6, 17, 18, and 19)

1.0. Document Purpose

The purpose of this document is to define the State of Maine procedures for implementing access control requirements that protect the confidentiality, integrity, and availability of State information assets. These procedures describe how the State fulfills the operational requirements for account management (AC-2), access enforcement (AC-3), separation of duties (AC-5), least privilege (AC-6), remote access (AC-17), wireless access (AC-18), and access control for mobile devices (AC-19). This document corresponds to the applicable controls and control enhancements within the Access Control (AC) Control Family of the National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5).[1]

2.0. Scope

2.1. These procedures apply to all State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch-managed services.

3.0. Procedure Conflict

If these procedures conflict with any law or union contract in effect, the terms of the existing law or contract prevail.

4.0. Roles and Responsibilities

Please refer to the Access Control Policy and Procedures (AC)[2] document for further information.

5.0. Management Commitment

The State of Maine is committed to following these procedures and the policy that it supports.

6.0. Coordination Among Agency Entities

6.1. Please refer to the Access Control Policy and Procedures (AC)[3] document.

7.0. Compliance

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in the removal of the individual's ability to access and use State of

[1] https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/AccessControlPolicy.pdf
[3] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/AccessControlPolicy.pdf

Maine data and systems. Employers of contractors will be notified of any violations.

7.3. Personnel are also subject to any applicable penalties for statutory requirements compliance violations. Depending on the requirement and the nature of the violation, penalties could include fines and/or criminal charges.

8.0. Procedures

The following standards apply to and represent the security controls established to meet an acceptable level of protection for the State of Maine from unauthorized information system access.

8.1. Account Management (AC-2, (1), (2), (3), (4), (7), (9), (12), (13))

8.1.1. All personnel who access State of Maine information assets must have an Active Directory (AD) account within the appropriate branch directory (Executive, Judicial, Legislative, etc.).

8.1.2. **8.1.2 Account Types**

8.1.2.1. OIT maintains the following account types to support agency missions and business functions:

8.1.2.1.1. individual accounts

8.1.2.1.2. role-based shared accounts

8.1.2.1.3. group accounts

8.1.2.1.4. system accounts

8.1.2.2. Additional finite access account types may exist when required for operational purposes.

8.1.3. **Account Request and Approval Workflow**

8.1.3.1. Agencies assign authorized officials to approve user access to the data they own.

8.1.3.2. Authorized agency personnel submit account requests to OIT through the Enterprise Ticketing System. Submitted requests must include required information and justification.

8.1.3.3. The ticket is automatically routed to the appropriate OIT information asset owner for fulfillment (for example, AD and File Services teams for AD accounts).

8.1.3.4. OIT fulfills the request and updates the ticket to notify the agency upon completion.

8.1.4. **Access Authorization Conditions**

8.1.4.1. When submitting account requests, agencies provide OIT with the information needed to establish access for each

user, including the intended users of the account, applicable group or role membership, and any access privileges or attributes tied to the agency's mission or regulatory obligations.

8.1.4.1.1. Authorized agency personnel include this information in the user access request submitted through the Enterprise Ticketing System.

8.1.4.1.2. Agencies use established OIT standards and Enterprise Ticketing System workflows to request creation, modification, disabling, or removal of accounts.

8.1.4.1.3. Access is established only when the agency has supplied the required approval information, the request aligns with how the system is intended to be used, and any additional attributes needed by OIT or the agency have been provided.

8.1.4.2. Access is granted only when:

8.1.4.2.1. a valid authorization exists,

8.1.4.2.2. intended system use is consistent with the request, and

8.1.4.2.3. all required attributes have been provided.

8.1.5. **Account Lifecycle Actions -** Agencies use established OIT standards and ITSM workflows to create, enable, modify, disable, and remove accounts for all account types.

8.1.6. **Agency Monitoring Obligations -** Agencies monitor usage of agency information asset accounts and must notify OIT when:

8.1.6.1. accounts are no longer required,

8.1.6.2. personnel transfer or terminate,

8.1.6.3. personnel information asset usage or need-to-know change.

8.1.7. **Credential Updates for Shared or Group Accounts -** Agencies must maintain a process to reissue shared or group account credentials whenever individuals leave the group.

8.1.8. **Microsoft Temporary Access Pass (TAP) for Account Provisioning and Recovery -** TAP may be used as an approved temporary authentication method only for initial account access, registration of approved MFA/authentication methods, account recovery, or emergency access scenarios. TAP shall not be used as a persistent or primary authentication method. TAP must be configured with a minimum password length of fifteen (15) alphanumeric characters, a

maximum validity period of eight (8) hours, and single-use enforcement. TAP does not authorize access from personally owned or otherwise non-State-issued/non-State-managed devices, and any TAP-enabled authentication must remain subject to applicable Conditional Access and identity verification controls. TAP issuance and use must be restricted to authorized administrators or approved automated identity workflows, and must be logged, monitored, and revoked upon suspected compromise or upon completion of the intended use.

8.1.9. **Automated Account Management (AC-2(1))**

8.1.9.1. OIT employs automated mechanisms available through AD and enterprise tools to support account provisioning, modification, and de-provisioning. Automation reduces administrative error and ensures consistent enforcement of access rules.

8.1.10. **Automated Notifications (AC-2(2)) -** The Enterprise Ticketing System provides automated notifications to account managers when accounts are created, modified, disabled, or removed, and when users are transferred or terminated.

8.1.11. **Disable Accounts (AC-2(3))**

8.1.11.1. AD-backed accounts are automatically disabled after 90 days of inactivity.

8.1.11.2. Agencies may request shorter disablement windows through ITSM to meet specific regulatory requirements.

8.1.11.3. Temporary and emergency accounts are automatically disabled within 96 hours of last use unless renewed through ITSM.

8.1.12. **Audit of Account Activity (AC-2(4)) -** OIT uses the Security Information and Event Management (SIEM) system to ensure logging of account-related events when required. These events support traceability and investigative needs and align with role-based access management workflows managed through the Enterprise Ticketing System.

8.1.13. **Logout Behavior Reference (AC-2(5)) -** User logout behavior is enforced through the device lock procedures described in AC-11 Session Lock. This control is implemented at the system level rather than through account-specific workflow.

8.1.14. **Privileged Role Monitoring (AC-2(7))**

8.1.14.1. OIT monitors:

8.1.14.1.1. privileged role assignments

8.1.14.1.2. changes to privileged attributes

8.1.14.2. Privileged access is limited to authorized personnel, enforces separation of duties, and must be used exclusively for administrative or elevated tasks.

8.1.15. **Restrictions on Shared and Group Accounts (AC-2(9)) -** Use of shared accounts is prohibited unless approved through the waiver process.

8.1.16. **Monitoring for Atypical Usage (AC-2(12)) -** Atypical usage of accounts is logged and monitored under the Audit and Accountability Policy and supporting procedures.

8.1.17. **Disable Accounts for High-Risk Individuals (AC-2(13))**

8.1.17.1. Account disabling actions may be requested through the Enterprise Ticketing System by authorized agency personnel.

8.1.17.2. OIT processes these requests promptly to support risk-based determinations.

8.1.17.3. In urgent cases, disabling actions may be expedited through direct coordination with OIT support teams.

8.1.17.4. Security personnel may immediately disable accounts associated with suspected or confirmed compromise.

8.1.17.5. All disabling actions are logged through the Enterprise Ticketing System for traceability.

8.1.18. Printers used to conduct State of Maine business must only connect to the State network via a wired connection; Ethernet and USB are both allowable.

8.1.19. For AD user accounts, no service is allowed for the creation or updating of the primary key-attributes. Some secondary key-attributes may be open for self-service updating.

8.2. Access Enforcement (AC-3, (7), (8), (9), (11), (14))

8.2.1. **Enforcement of Authorized Access (AC-3)**

8.2.1.1. OIT enforces approved access authorizations for users and system processes based on agency-defined roles, assigned job responsibilities, and documented business needs.

8.2.1.2. Agencies submit access requests, modifications, and terminations through the Enterprise Ticketing System with justification that aligns to approved access control policies and regulatory requirements.

8.2.1.3. OIT ensures that access enforcement mechanisms implemented within enterprise systems and applications

reflect the authorization decisions documented in submitted and approved requests.

8.2.1.4. OIT enforces restrictions on access by day, date, or time when required to support specific operational, security, or regulatory conditions.

8.2.2. **Role-Based Access Control (AC-3(7))**

8.2.2.1. OIT provisions access based on agency-defined user roles that specify the systems, data, and resources each role may access.

8.2.2.2. Access assignments are validated during provisioning to ensure alignment with job duties and approved business needs.

8.2.2.3. Role changes initiated by agencies trigger automated or manual updates to system access to ensure privileges remain accurate and appropriate.

8.2.3. **Revocation of Access Authorizations (AC-3(8))**

8.2.3.1. OIT revokes system, application, and data access when agency-approved permissions or group memberships change.

8.2.3.2. Enterprise systems such as Active Directory enforce revocation immediately or at the next authentication event.

8.2.3.3. When technical limitations prevent immediate revocation, OIT ensures the access change is synchronized across managed systems as soon as the session ends or the resource is re-accessed.

8.2.4. **Release of Information to External Systems (AC-3(9))**

8.2.4.1. OIT releases information to external systems only when the receiving environment has agency-defined safeguards in place that provide adequate protection for the information.

8.2.4.2. Agencies validate that the external safeguards they establish meet all applicable Federal, State, and agency requirements.

8.2.4.3. OIT applies procedural controls, such as print-release oversight or managed file transfer requirements, to prevent unauthorized individuals from accessing released information.

8.2.5. **Restricted Access to Specific Information Types (AC-3(11))**

8.2.5.1. OIT, in coordination with agencies, restricts access to data repositories containing regulated or sensitive information

such as FTI, PHI, CJI, and other classification-based information types.

8.2.5.2. Only users with a documented need to know and job-specific responsibilities are authorized for access to such data.

8.2.5.3. Access restrictions are applied at the system, application, or data-element level depending on the sensitivity of the information.

8.2.5.4. agency approval workflows to authorize any changes to an application's access requirements after installation.

8.2.6. **Individual Access to PII or PHI (AC-3(14)) –** OIT supports agency-defined privacy practices by maintaining secure systems and access controls that enable agencies to provide individuals access to their PII or PHI. Agencies are responsible for defining access criteria, handling requests, and ensuring compliance with applicable privacy regulations.

8.3. Separation of Duties (AC-5)

8.3.1. Both the agencies and OIT identify any required separation of duties for their agency information assets, consistent with applicable Federal laws, Executive orders, directives, policies, regulations, standards, and guidance. Examples include:

8.3.1.1. Ensuring that audit functions are not performed by personnel responsible for administering access control;

8.3.1.2. Maintaining a limited group of administrators with access based on the users' roles and responsibilities;

8.3.1.3. Ensuring that critical mission functions and information asset support functions are divided among separate individuals;

8.3.1.4. Ensuring that information asset testing functions (for example, user acceptance, quality assurance, and information security) and production functions are divided among separate individuals or groups; and

8.3.1.5. Ensuring that an independent entity, not the business owner, system developer(s), or maintainer(s), or system administrator(s) responsible for the information asset, conducts information security testing of the information asset.

8.3.2. Agencies and OIT document separation-of-duties requirements when they apply and define the access authorizations needed to support these requirements.

8.3.2.1. Agencies collaborate with the application development managers and account managers to implement agency-identified, required information asset separation of duties for OIT-managed systems.

8.4. Least Privilege (AC-6, (1), (2), (5), (6), (7), (8), (9), (10))

8.4.1. Agencies and OIT apply least privilege to all information assets by ensuring user and system access is limited to the functions required to perform assigned responsibilities. Access determinations are based on role responsibilities, operational needs, and agency security requirements.

8.4.1.1. For the information assets it supports, OIT employs the principle of least privilege, which allows authorized access for users (or processes acting on behalf of users) only as necessary for the user to accomplish assigned tasks in accordance with job duties.

8.4.1.2. OIT explicitly authorizes access to system utilities by requiring that they be made available only to those with a legitimate business case.

8.4.1.3. OIT requires that system administration accounts (for example, root access) be limited to the smallest group possible and be subject to the principle of least privilege.

8.4.1.4. OIT requires that administrators first log in as themselves (ordinary user) before escalating privileges to the level of an administrator.

8.4.1.5. OIT implements technical and procedural safeguards to prevent non privileged users from performing privileged actions or altering implemented security controls. These safeguards apply across all OIT supported systems and environments.

8.4.2. OIT restricts privileged accounts on the information asset to defined personnel or roles (defined in the applicable security plan).

8.4.3. OIT audits the execution of privileged functions.

8.4.4. OIT supported information assets enforce separation between privileged and non-privileged actions to prevent unauthorized individuals from executing privileged functions or modifying implemented controls.

8.4.5. **Privileged Access by Non-Organizational Users (AC-6(6))** - Only State employees or authorized contractors may hold Active Directory accounts or other credentials used to access privileged functions.

8.4.6. **Privilege Review (AC-6(7))**

8.4.6.1. Privileges assigned to elevated roles are reviewed at a frequency defined by regulatory frameworks and agency security plans.

8.4.6.2. Agency and OIT gatekeepers validate ongoing need for elevated access using approved workflows, including Enterprise Ticketing System processes and role-based access reviews.

8.4.7. **Privilege Levels for Code Execution (AC-6(8))**

8.4.7.1. OIT requires that software execute only with the privileges granted to the initiating user unless elevated permissions are explicitly authorized and technically controlled.

8.4.7.2. Applications and scripts run with standard user permissions unless elevation is required for approved administrative functions.

8.4.7.3. Elevated execution is restricted to authorized personnel and approved processes.

8.4.7.4. Code requiring elevated privileges undergoes review and approval through OIT change management.

8.4.7.5. Endpoint protection, operating system controls, and allow lists enforce privilege separation and prevent unauthorized privilege escalation.

8.4.7.6. These requirements apply to all agency-defined software, including locally installed applications, scripts, macros, and automation tools, regardless of platform or hosting environment.

8.4.8. **Logging and Analysis of Privileged Activity (AC-6(9))** - Privileged activity is logged and monitored under the Audit and Accountability Policy and Procedures (AU)[4].

8.4.9. **Enforcement of Privileged Operation Requirements (AC-6(10))** - Privileged functions, including modification of security or privacy configurations, may only be performed by personnel who possess the required authorizations. OIT supported systems enforce separation between privileged and non-privileged functions to prevent unauthorized execution.

8.5. Remote Access (AC-17, (1), (2), (3), (4), (9))

8.5.1. **Inbound and Outbound Wide Area Network Remote Access (AC-17)**

[4] http://inet.state.me.us/oit/policies/documents/AuditAccountabilityPolicyProcedures.pdf

8.5.1.1. Inbound Remote Access VPN to the State of Maine Wide Area Network must be via the Cisco AnyConnect application installed on the individual device.

8.5.1.2. In rare cases, the CISO may approve State-owned or managed devices to connect to a partner's corporate network for business reasons, requiring installation of the partner's VPN application. The Information Security Office will maintain an authorized list of approved VPN applications and track associated devices and use cases.

8.5.2. **Split-Tunnel Restriction (AC-17) -** Irrespective of anything else, under no circumstance is a device owned and/or managed by the State of Maine allowed to initiate a dual-VPN split-tunnel, i.e., a simultaneous VPN connection to both the State of Maine Wide Area Network and a remote partner's corporate network.

8.5.3. **In-State Remote Access (AC-17, (1), (2), (3), (4))**

8.5.3.1. Both the agencies and OIT must ensure that usage restrictions, configuration and connection requirements, and implementation guidance for In-State Remote Access (see Definitions) to agency information assets are established, and that remote access is authorized prior to allowing connections, consistent with applicable federal laws, Executive orders, directives, policies, regulations, standards, and guidance.

8.5.3.1.1. **Protect Remote Access Sessions (AC-17(2)) -** OIT requires that In-State Remote Access occur via established Virtual Private Networks (VPNs) utilizing multifactor authentication and host verification (host operating system checker and antimalware).

8.5.3.1.2. Secure tokens, assigned to specific individuals, are required for In-State Remote Access. These secure tokens are issued by OIT upon receipt of a request from authorized agency personnel.

8.5.3.1.3. Office 365 leases that allow remote access by trusted devices are granted for 30 days. Each time a device connects to the internal network, the lease is renewed.

8.5.3.1.4. **Monitor and Control Remote Access Methods (AC-17(1)) -** OIT monitors and controls In-State Remote Access, using a secure portal with automated, standard reporting capabilities.

8.5.3.1.4.1. Administrative tools are used to kill rogue connections that are identified.

8.5.3.1.5. **Cryptographic Protection for Remote Access (AC-17(2)) -** OIT utilizes end-to-end VPN encryption to protect the confidentiality and integrity of remote connections.

8.5.3.1.6. **External Network Connection Restrictions (AC-17(3)) -** OIT utilizes two distinct, dedicated domain entry points to route all In-State Remote Access.

8.5.3.1.7. **Restrict Privileged Commands via Remote Access (AC-17(4)) -** OIT restricts and monitors the use of privileged commands and access to security-relevant information, particularly when conducted remotely.

8.5.3.1.7.1. Execution of privileged commands and access to administrative functions are authorized only through approved OIT-managed Virtual Private Network (VPN) connections. All remote connections must comply with OIT's enforced security standards, including Multi-Factor Authentication (MFA) and device compliance verification.

8.5.3.1.7.2. Privileged remote activity is logged, monitored, and subject to alerting under the Audit and Accountability (AU) controls. The SIEM provides automated detection and alerting for suspicious or unauthorized privileged actions. Security personnel review logs and respond to anomalies or unauthorized activity as needed, consistent with incident response and monitoring procedures defined under the Audit and Accountability (AU) controls. These records provide assessable evidence of privileged activity and support investigations and compliance verification.

8.5.3.1.8. OIT requires that devices that access the State network meet the following security safeguards:

8.5.3.1.8.1. Up-to-date system patches;

8.5.3.1.8.2. Current antimalware; and

8.5.3.1.8.3. Automatic code execution disabled.

8.5.4. **Short-Term Out-of-State Domestic Remote Access (AC-17, (1), (2), (3), (4))**

8.5.4.1. Personnel intending Short-Term (see Definitions) Out-of-State Domestic Remote Access (see Definitions) must make a request to their supervisor.

8.5.4.2. The supervisor must acknowledge, and either approve or deny the applicant personnel's request. Should the supervisor deny the request, no further action is necessary.

8.5.4.3. Should the supervisor approve the request and should the applicant personnel happen to be a State employee (as opposed to a contractor), the supervisor ensures compliance with the agency's out-of-state travel approval workflow. Should the agency approve such out-of-state travel, then the State employee proceeds with the Short-Term Out-of-State Domestic Remote Access.

8.5.4.4. For contractors, the Short-Term Out-of-State Domestic Remote Access is *not* subject to approval by the DAFS Bureau of Human Resources.

8.5.4.5. Otherwise, the Short-Term Out-of-State Domestic Remote Access follows the same procedure as In-State Remote Access (see 8.5.3, above).

8.5.5. **Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access (irrespective of Long or Short-Term) (AC-17, (1), (2), (3), (4))**

8.5.5.1. Any data that is subject to Federal compliance mandates (including, but not limited to, Criminal Justice Information Systems (CJIS), Internal Revenue Service (IRS), and Centers for Medicare and Medicaid Services (CMS)) must never be subjected to Foreign Remote Access.

8.5.5.2. Compared to In-State Remote Access and Short-Term Out-of-State Domestic Remote Access, Long-Term Out-of-State Domestic Remote Access (see Definitions) and Foreign Remote Access (see Definitions) demand additional review, and the related workflow is described below. Unless

explicitly called out in this section, all other details follow the In-State Remote Access described in section 8.5.3.

8.5.5.3. The State of Maine must ensure that Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access to agency information assets is explicitly authorized prior to allowing such access, and is consistent with applicable federal laws, Executive orders, directives, policies, regulations, standards, and guidance.

8.5.5.3.1. Personnel intending Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access to State information must make a request to their supervisor.

8.5.5.3.2. The supervisor must acknowledge, and either approve or deny the applicant personnel's request. Should the supervisor deny the request, no further action is necessary. Supervisors must exercise great caution before approving Foreign Remote Access. Foreign Remote Access is fraught with numerous variables that make risk determination challenging. Such variables include, but are not limited to, foreign relations, international terrorism, international law, crime statistics at that locale, etc. Some general guidance may be found in the U.S. State Department Travel Advisories.[5]

8.5.5.3.3. Should the supervisor approve of the Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access request of the applicant personnel, then, only for State employees, the supervisor submits an approval request to the DAFS Bureau of Human Resources. This step is *not* necessary for contractors. For State employees, should the DAFS Bureau of Human Resources deny the request, no further action is necessary.

8.5.5.3.4. Should, for State employees, the DAFS Bureau of Human Resources approve the Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access, the supervisor submits a request, through the OIT Enterprise Ticketing System, no later than 10 business days prior to the

[5] https://travel.state.gov/content/travel/en/traveladvisories/traveladvisories.html/

commencement of the requested Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access. (The OIT Enterprise Ticketing System service is called "Application for Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access".) At a minimum, such a request must include:

8.5.5.3.4.1. Name (as listed in the AD) and Maine.Gov directory email address of the applicant personnel;

8.5.5.3.4.2. The Title and the Job Responsibilities of the applicant personnel;

8.5.5.3.4.3. The full list of information assets the applicant personnel will access, and the data classification of such assets. (See the Data Classification Policy[6] for more details);

8.5.5.3.4.4. The projected timeline of the Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access request (see definitions of Long-Term and Short-Term);

8.5.5.3.4.5. The device(s) that would be used for the Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access, including whether said devices are managed by the OIT;

8.5.5.3.4.6. Whether the accessing location is going to be stationary for the stated time, or not. If not, the complete list of locations and times of such access must be provided; and

8.5.5.3.4.7. Either an explicit statement or evidence of the supervisor's approval of this Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access request; and

[6] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/DataClassificationPolicy.pdf

8.5.5.3.4.8. A copy of the approval from the DAFS Bureau of Human Resources for State employees.

8.5.5.3.5. This Enterprise Ticketing System request is assigned to OIT Security.

8.5.5.3.6. OIT Security:

8.5.5.3.6.1. Conducts a risk assessment of the destination;

8.5.5.3.6.2. Provides a recommendation to the Chief Information Security Officer (CISO), who either approves or denies the request. Denied requests are provided to the Chief Information Officer (CIO) for a final determination; and

8.5.5.3.6.3. If approved by the CISO/CIO, the ticket is handed off to other OIT service verticals for operational implementation.

8.5.5.3.7. In the case of approved Long-Term Out-of-State Domestic Remote Access, the applicant personnel will continue using their regular work laptop.

8.5.5.3.8. In the case of approved Foreign Remote Access, the following will be executed:

8.5.5.3.8.1. The applicant personnel are provisioned with a basic laptop and multifactor authentication for travel;

8.5.5.3.8.2. This basic laptop is *only* utilized to connect to the second virtual workstation described below. No actual State work is performed on the basic laptop. No State data is ever stored on the basic laptop; and

8.5.5.3.8.3. The applicant personnel are also provisioned with a second virtual workstation inside the State Wide Area Network. All actual work is performed on this workstation.

8.5.5.3.9. Irrespective of the supervisor's approval, depending upon the assessed risk to State

information assets from the requested Long-Term Out-of-State Domestic Remote Access or Foreign Remote Access, OIT retains the right to deny the request at any point in the future.

8.5.5.3.10. TLP: Amber, TLP: Amber+Strict, and TLP: Red data cannot be accessed by agency personnel located in foreign countries, with the exception of U.S. territories, embassies, and military installations. Further, TLP: Amber, TLP: Amber+Strict, and TLP: Red data may not be received, processed, stored, transmitted, or disposed of by information assets located overseas (See the Data Classification Policy[7] for more details).

8.5.6. **Disconnect/Disable Remote Access (AC-17(9)) -** OIT, with support from the agencies, must have the ability to expeditiously disconnect users remotely accessing agency information systems and/or disable future remote access in order to secure agency information assets. In addition to the below, see also 5.1.3. of Network Device Management Policy[8].

8.5.6.1. The CIO, CISO, Networking, CIS, or Client Tech management is authorized to order:

8.5.6.1.1. The immediate disconnection of remote network connections, and/or

8.5.6.1.2. The immediate disabling of future remote network access.

8.5.6.2. After the order is received, the connection(s) should be terminated, and the disabling of future remote connection(s) should be completed promptly, preferably within 15 minutes.

8.5.6.3. Networking, CIS, or Client Tech management will notify the CISO of the actions taken.

8.6. Wireless Access (AC-18, (1), (3)) - Both the agencies and OIT must ensure that usage restrictions, configuration and connection requirements, and implementation guidance for wireless access to agency information assets are established and that wireless access is authorized prior to allowing connections, consistent with applicable Federal laws, Executive orders, directives, policies, regulations, standards, and guidance.

[7] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/DataClassificationPolicy.pdf
[8] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/NetworkDeviceManagementPolicy.pdf

8.6.1. **Wireless Access Security Controls (AC-18(1)) –** OIT requires that agencies comply with the wireless access methods provided by OIT when accessing the State network. Wireless access points are:

8.6.1.1. SOM AIRE: The State of Maine's secured wireless network, two-factor authentication: Certificate and AD credentials;

8.6.1.2. SOM GUEST: The wireless network for temporary, incidental connection of vendors, contractors, or business partners. It is not intended for use with guests for more than 6 days, nor for self-sponsored personal devices (see Definitions). User audits identifying "permanent type" connections on the SOM GUEST can lead to charges of network access rates to the agency.

8.6.2. **Unauthorized Wireless Access Point Restrictions (AC-18(1)) –** OIT strictly prohibits the installation of wireless access points that are not managed by OIT.

8.6.3. **Baseline Wireless Security Controls (AC-18(1)) –** The following restrictions and access controls are integral to all wireless service:

8.6.3.1. Encryption protection is enabled;

8.6.3.2. SOM AIRE access points are placed in secure areas;

8.6.3.3. A firewall is implemented between public access and the entire network;

8.6.3.4. Organizational policy related to wireless client access configuration and use is documented by OIT;

8.6.3.5. Wireless intrusion and detection system(s) are employed.

8.6.4. **Compensating Wireless Security Controls (AC-18, (1), (3)) –** OIT employs compensating controls in lieu of select wireless access controls as follows:

8.6.4.1. Access points are not shut down when not in use, but instead are set to degrade off-hours;

8.6.4.2. Machine (MAC) address authentication does not take place; instead, AD authentication is utilized;

8.6.4.3. Static IP addresses are not used for client devices; instead, Dynamic Host Configuration Protocol (DHCP) is utilized; and

8.6.4.4. Wireless activity monitoring, recording, and review is not conducted on a regular basis; instead, OIT has overall monitoring, recording, and review that extends to wireless.

8.6.4.5. **Disable Wireless Capabilities Prior to Deployment (AC-18(3)) –** OIT disables wireless networking capabilities on

system components prior to deployment, enabling them only when required to meet agency needs or as specified in approved policy.

8.6.5. **Wireless Authentication and Encryption Requirements (AC-18(1))** Wireless access is protected using authentication and encryption.

8.6.6. **DHCP Deployment and Wireless Provisioning Controls (AC-18(1)) –** OIT uses DHCP for streamlining deployment and increased security. DHCP allows wireless access points to be sent to the field without being pre-provisioned or primed. The wireless access points are lightweight and cannot be accessed until administrative credentials are pushed to them from the controller. This procedure was approved for use by the IRS instead of using static IP addresses.

8.6.7. **Wireless Monitoring Reference (AC-18(1)) –** See the System and Information Integrity Policy,[9] Information System Monitoring (SI-4) for more details.

8.6.8. Printers used to conduct State of Maine business must only connect to the State network via a wired connection; Ethernet and USB are both allowable.

8.7. Access Control for Mobile Devices (AC-19, (5))

8.7.1. **Mobile Device Usage Restrictions (AC-19) -** Both the agencies and OIT must ensure that usage restrictions, configuration and connection requirements, and implementation guidance for mobile device access to agency information assets are established and that wireless access is authorized prior to allowing connections, consistent with applicable Federal laws, Executive orders, directives, policies, regulations, standards, and guidance. Such rules apply irrespective of whether the mobile device is issued by the State or is personally owned.

8.7.1.1. **Encryption and Management Requirements (AC-19(5))** The OIT Mobile Device Policy[10] establishes the requirements for mobile device access to the State network. These requirements include, but are not limited to:

8.7.1.1.1. Authorization requirements for mobile device access to the State network;

8.7.1.1.2. Mobile Device Encryption Requirements, including the use of either full-device encryption or container-based encryption to protect the confidentiality and integrity of organizational

[9] https://www.maine.gov/oit/policies/SystemInformationIntegrityPolicy.pdf
[10] https://www.maine.gov/oit/policies/MobileDevicePolicy.pdf

information on State-issued or approved personally owned mobile devices; and

8.7.1.1.3. Mobile device management software requirements.

8.7.1.2. Additionally, OIT:

8.7.1.2.1. Monitors for unauthorized connections of mobile devices to information assets;

8.7.1.2.2. Enforces requirements for the connection of mobile devices to information assets; and

8.7.1.2.3. Issues specially configured mobile devices to individuals traveling to locations that the organization deems to be of significant risk, in accordance with applicable agency and OIT policies and procedures.

8.7.2. Printers used to conduct State of Maine business must only connect to the State network via a wired connection; Ethernet and USB are both allowable.

9.0. Document Details

9.1. Initial Issue Date: August 30, 2019

9.2. Latest Revision Date: May 29, 2026

9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov

9.4. Approved By: Chief Information Officer, OIT

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology[11]

9.6. Waiver Process: Waiver Policy[12]

9.7. Distribution: Internet[13]

10.0. Review

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after

[11] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[12] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[13] https://www.maine.gov/oit/policies-standards

withdrawal or replacement and then destroyed in accordance with guidance[14] provided by Maine State Archives. Retention of these documents will be subject to any future State Archives General Schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA),[15] certain public records exceptions may limit disclosure of agency records related to information technology infrastructure and systems, as well as security plans, procedures, or risk assessments. Information contained in these records may be disclosed to the Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

[14] https://www.maine.gov/sos/sites/maine.gov.sos/files/content/assets/GS1Administrative.pdf
[15] https://legislature.maine.gov/statutes/1/title1sec402.html

13.0. Definitions

13.1. Access Approval Process: The method by which a user's request for access to an information asset is reviewed, verified, and authorized in accordance with applicable policy and least-privilege principles.

13.2. Access Control List (ACL): A ruleset applied to network devices, systems, or applications to permit or deny communication based on defined criteria such as protocol, port, source address, or destination address.

13.3. Access Control: The process of granting or denying specific requests to 1) obtain and use information and related information processing services; and 2) enter specific physical facilities (for example, Federal buildings, military establishments, border crossing entrances).

13.4. Active Directory (AD): The State of Maine's enterprise directory service that provides centralized authentication, authorization, account management, and policy enforcement.

13.5. Agency Data Custodian: Agency official, who, based on his or her position, is a fiduciary owner of specific agency information assets. For instance, the Labor Bureau of Unemployment Compensation Director (or designee) is the Agency Data Custodian for Unemployment Compensation Information Assets, and the Department of Health and Human Services Office of Family Independence Director (or designee) is the Agency Data Custodian for Benefits Information Assets.

13.6. Application Owner: The individual within the OIT responsible for the management, security, and operational oversight of specific information assets or applications

13.7. Authentication: The process of verifying the identity of a user, process, or device as a prerequisite to granting access to an information asset.

13.8. Authorization: The process of granting an authenticated user permission to access specific information, systems, or services based on approved rights and privileges.

13.9. Authorized User: An individual who has approved access to an information asset to perform job responsibilities.

13.10. Availability: Timely and reliable access to and use of information assets.

13.11. Boundary Protection: The set of controls used to monitor and restrict information flow across network boundaries and security domains.

13.12. Confidentiality: The state of being kept private or secret, including preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.

13.13. Compensating Controls: Alternative security controls used to satisfy a requirement when the primary control cannot be implemented due to operational or technical limitations.

13.14. Controlled Unclassified Information (CUI): Information that requires safeguarding or dissemination controls pursuant to applicable law, regulation, or government-wide policy, but is not classified.

13.15. Data Mining: The automated or large-scale analysis of data sets to discover patterns, relationships, or anomalies that may indicate unauthorized access or misuse.

13.16. Demilitarized Zone (DMZ): A host or network segment inserted as a "neutral zone" between an organization's private network and the internet.

13.17. Foreign Remote Access: A less common and unusual variety of Remote Access, where State of Maine personnel remotely access State of Maine information asset(s) from a location outside the United States, U.S. territories, embassies, or military installations.

13.18. Group Policy Object (GPO): A configuration management mechanism used within AD to enforce security settings and standardize system behavior.

13.19. Human Resources Management System (HRMS): The system used by the State of Maine to manage personnel records and processes, including automated account provisioning.

13.20. Identity and Access Management: The set of processes used to establish user identity, assign and manage access rights, and control authentication and authorization.

13.21. Incident Response: The actions taken to detect, analyze, contain, remediate, and recover from a cybersecurity or operational incident.

13.22. Information Assets: Used interchangeably with Information Systems. A discrete, identifiable piece of information technology, including hardware, software, firmware, systems, services, and related technology assets used to execute work on behalf of OIT or another State agency. (National Institute of Standards and Technology (NIST) Special Publication (SP) 800-30).

13.23. Information Technology Service Management (ITSM): The formalized framework through which OIT manages service requests, incident resolution, change management, and access approval.

13.24. In-State Remote Access: The more common, and default, variety of Remote Access, where State of Maine personnel remotely access State of Maine information asset(s) from a location inside the State of Maine, but outside a State of Maine office location.

13.25. Integrity: The accuracy and consistency (validity) of data over its lifecycle. Guarding the integrity of information assets against improper modification or destruction includes ensuring information nonrepudiation and authenticity.

13.26. Logical Session: A user-initiated interaction with a system that begins at authentication and ends when the user logs out, or the system terminates the session.

13.27. Long-term: 30 days or more.

13.28. Mobile Device Management (MDM): Technology used to manage, secure, configure, and monitor mobile devices used to access State information assets.

13.29. Nonpublic Information: Information that is not authorized for public release, including confidential, sensitive, proprietary, or legally restricted data.

13.30. Out-of-State Domestic Remote Access: A less common variety of Remote Access, where State of Maine personnel remotely access State of Maine information asset(s) from a location outside the State of Maine, but within the United States, including U.S. territories, embassies, and military installations.

13.31. Personal Devices: Portable storage media, mobile computing devices, or any personal technology capable of storing, transmitting, or receiving information. Include the following categories:

13.31.1. Portable cartridge or disk-based, removable storage media (for example, floppy disks, compact disks, USB flash drives, external hard drives, and other flash memory cards or drives that contain nonvolatile memory).

13.31.2. Portable computing and communication devices with information storage capability (for example, notebook/laptop computers, personal digital assistants, cellular telephones, digital cameras, and audio recording devices); and

13.31.3. Any other mobile computing device small enough to be easily carried by an individual, able to wirelessly transmit or receive information, and have local, nonremovable data storage and a self-contained power source.

13.32. Personally Identifiable Information (PII): Information that can be used to distinguish or trace an individual's identity.

13.33. Principle of Least Privilege: A security principle whereby users are assigned the minimum access necessary to perform their job responsibilities. Access is granted for the shortest duration possible.

13.34. Privileged User: A user who is granted rights that go beyond those of a typical business user to manage and maintain IT systems. Usually, these rights include administrative access to networks and devices and are separate from users' administrative access to their own workstations.

13.35. Remote Access: Access to State information assets initiated from outside a State of Maine office location.

13.36. Remote Access VPN: A Remote Access VPN differs from a Site-to-Site (S2S) VPN (See https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SiteToSiteVPNPolicy.pdf for more information). An S2S VPN connects two different corporate networks through an encrypted tunnel. Whereas a Remote Access VPN connects an individual device to a corporate network through an

encrypted tunnel. Establishing a Remote Access VPN involves installing a native operating system application on the individual device, which forms one endpoint of the encrypted tunnel; The other endpoint being the remote corporate network. From the standpoint of a corporate network, a Remote Access VPN can be either Inbound or Outbound. An Inbound Remote Access VPN connects a foreign device to the corporate network. Whereas, an Outbound Remote Access Network connects a device within the corporate network to a remote partner's corporate network.

13.37. Separation of Duties: A security principle that divides critical functions among staff members to ensure that no one individual has enough information or access privileges to perpetrate damaging fraud (i.e., no user should be given enough privileges to misuse the system on their own).

13.38. Service Level Agreement (SLA): A formal agreement describing expected service performance, responsibilities, and security requirements between parties.

13.39. Session Termination: A system-enforced end to a logical session due to user logout, timeout, or security controls.

13.40. Short-Term: Fewer than 30 days.

13.41. Trust Relationship: A formal or implicit agreement defining the level of assurance between organizations, permitting limited reliance on each other's security controls.

14.0. Abbreviations

14.1.	ACL:	Access Control List
14.2.	AD:	Active Directory
14.3.	AT:	Awareness and Training
14.4.	CA:	Security Assessment and Authorization
14.5.	CISO:	Chief Information Security Officer
14.6.	CUI:	Controlled Unclassified Information
14.7.	DAFS:	Department of Administrative and Financial Services
14.8.	FOAA:	[Maine] Freedom of Access Act
14.9.	GPO:	Group Policy Object
14.10.	HRMS:	Human Resources Management System
14.11.	ISO:	OIT Information Security Office
14.12.	ITSM:	Information Technology Service Management (i.e. Enterprise Ticketing System)
14.13.	MOA:	Memorandum of Agreement
14.14.	NIST:	National Institute of Standards and Technology
14.15.	OIT:	[Maine] Office of Information Technology

14.16. PII: Personally Identifiable Information

14.17. SLA: Service Level Agreement

14.18. VPN: Virtual Private Network